Botium Toys

INTERNAL SECURITY AUDIT REPORT

Assessment: NIST CSF, PCI DSS, GDPR
Target: IT Infrastructure & Compliance

1. Audit Scope and Objectives

Scope: Internal IT systems, physical facility access controls, data privacy management, and regulatory compliance alignment with PCI DSS, GDPR, and SOC frameworks.

Goal: Evaluate the current state of organizational security controls, identify critical risks and vulnerabilities, and formulate actionable recommendations to establish compliance and elevate the company's overall security posture as it expands into international e-commerce.

2. Controls Assessment: Technical & Operational Controls

Evaluation of core access management, network safeguards, and operational continuity configurations:

CONTROL AREA	STATUS	AUDIT NOTES & FINDINGS
Least Privilege	**No**	Access rights are not role-segmented; user permissions are overly broad across departments.
Disaster Recovery Plans	**No**	No formalized DR documentation, operational recovery targets (RTO/RPO), or business continuity plans.
Password Policies	**Yes**	Baseline policies established; require enhanced complexity and mandatory MFA enforcement.
Separation of Duties	**No**	Administrative conflicts exist; single staff members maintain conflicting access to dual critical roles.
Firewall	**Yes**	Active network perimeter inspection configured and operational.
Intrusion Detection System (IDS)	**No**	No network or host-based IDS deployed; automated threat detection capability is absent.
Data Backups	**Yes**	Routine data backups performed; formal restoration integrity testing not documented.
Antivirus Software	**Yes**	Endpoint antivirus software installed, active, and routinely updated with definition feeds.

2. Controls Assessment: Data, System & Physical Security (Continued)

Assessment of encryption standards, legacy infrastructure maintenance, and facility safeguards:

CONTROL AREA	STATUS	AUDIT NOTES & FINDINGS
Manual Legacy Maintenance	**Yes**	System administration heavily relies on manual legacy patching, presenting vulnerability overhead.
Encryption	**No**	Sensitive customer and organizational data is stored and transmitted unencrypted by default.
Password Management System	**No**	No enterprise password vault; credential storage and hygiene left to individual user discretion.
Physical Locks	**Yes**	Standard physical perimeter security and keyed access controls are maintained.
CCTV Surveillance	**Yes**	CCTV operational across main entrance, storefront, and primary warehouse zones.
Fire Detection / Suppression	**Yes**	Functional smoke detection sensors and automated sprinkler systems installed facility-wide.

3. Regulatory & Framework Compliance Checklist

PCI DSS

REQUIREMENT	STATUS
Authorized-only card access	**Yes**
Secure card data storage	**No**
Encryption implemented	**No**
Enforced password policies	**Yes**

GDPR

REQUIREMENT	STATUS
E.U. customer data secured	**No**
72-hr breach notification plan	**No**
Data classified & inventoried	**No**
Privacy policy enforced	**Yes**

SOC 1 / SOC 2

REQUIREMENT	STATUS
User access policies exist	**Yes**
PII / SPII confidentiality	**No**
Data integrity verification	**Yes**
System availability controls	**Yes**

4. Key Risks Identified

- **Lack of Sensitive Data Encryption:** Unencrypted storage and transit of financial and personal information exposes Botium Toys to severe regulatory fines and catastrophic breach impact.
- **No Intrusion Detection System (IDS):** Absence of real-time network and host-level monitoring leaves malicious activity undetected during early intrusion stages.
- **Lack of Disaster Recovery or Incident Response Plan:** Without documented recovery protocols or testing, business continuity is severely compromised during major security incidents or outages.
- **GDPR Non-Compliance:** The organization lacks required data classification, personal data inventories, and a formal 72-hour breach reporting workflow for E.U. customers.
- **Weak Separation of Duties & Overbroad Access:** Overlapping administrative roles and missing least-privilege enforcement increase vulnerability to internal fraud or unintentional human error.

5. Prioritized Recommendations

1. **Implement Least Privilege Access:** Limit access rights strictly by job function using Role-Based Access Control (RBAC), eliminating unnecessary administrative privileges.
2. **Establish a Disaster Recovery Plan:** Develop formalized DR protocols including routine backup validation, RTO/RPO metrics, and emergency contact procedures.
3. **Deploy an Intrusion Detection System (IDS):** Install network sensors to monitor anomalous activity and alert security personnel to threats in real time.
4. **Apply Data Encryption:** Encrypt all sensitive data at rest and in transit, specifically prioritizing payment transactions and customer databases.
5. **Automate Legacy Systems Monitoring:** Transition from manual patching to automated vulnerability management to decrease response times and reduce configuration errors.
6. **Adopt an Enterprise Password Management Tool:** Mandate complex password policies paired with multi-factor authentication (MFA) and a centralized credential vault.
7. **Ensure GDPR Alignment:**
    - Establish an operational 72-hour breach notification workflow.
    - Conduct a thorough data inventory to classify personal records of E.U. customers.
    - Execute mandatory security awareness and data handling training for relevant staff.